Bloque 2: Ecosistema OWASP y Protección Proactiva

FADENA

OWASP y Protección Proactiva

Ing. Roxana Quiroga Sollinger

OWASP TOP 10 Parte 1



Módulo 3: OWASP y Protección Proactiva

FADENA

3.1 OWASP

3.2 OWASP TOP 10

3.3 Protección Proactiva

3.4 Defensa en Profundidad



3.2 OWASP TOP 10

OWASP TOP 10

https://top10.owasp.org/2025/

El OWASP Top 10 es un documento de referencia sobre concienciación dirigido a desarrolladores y a la seguridad de aplicaciones web. Representa un amplio consenso sobre los riesgos de seguridad más críticos para las aplicaciones web.

FADENA

3.2 OWASP TOP 10

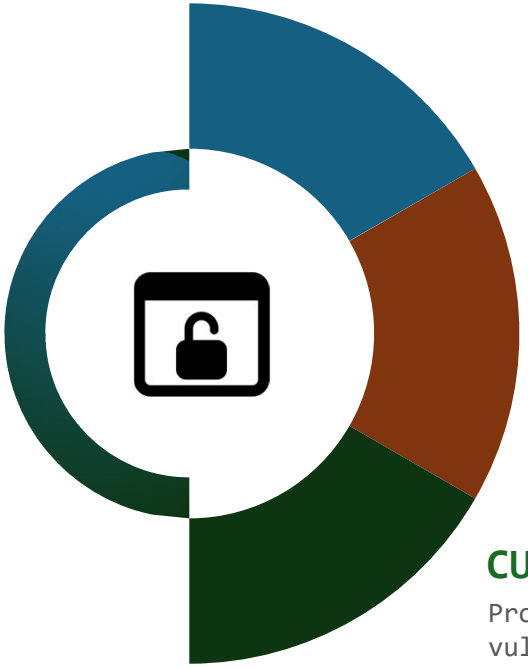
Seguridad de las Aplicaciones Web

La falsa seguridad web

El cifrado TLS y el cumplimiento de normas PCI no garantizan que una aplicación esté protegida frente a ataques reales.

La ilusión de la protección

Existe una percepción generalizada de seguridad impulsada por mensajes comerciales, sellos y tecnologías de cifrado convencionales.



USO GENERALIZADO DE TLS

Sitios web prometen seguridad total mediante cifrado de 256 bits para impedir el acceso no autorizado.

VALIDACIÓN DE CERTIFICADOS

Se insta al usuario aconfiar su información personal al sitio.

CUMPLIMIENTO NORMATIVO PCI

Promoción de análisis diarios de vulnerabilidades para certificar protección frente a ataques.

FADENA

3.2 OWASP TOP 10

OWASP TOP 10 - 2025

A01 Broken Access Control

El control de acceso aplica políticas para garantizar que los usuarios no actúen más allá de los permisos que tienen asignados.

A02 Security Misconfiguration

La mala configuración de seguridad ocurre cuando un sistema, aplicación o servicio en la nube se configura incorrectamente desde una perspectiva de seguridad, creando vulnerabilidades.

A03 Software Supply Chain Failures

Son fallos o vulneraciones en el proceso de creación, distribución o actualización de software.

A04 Cryptographic Failures

Los avances tecnológicos permiten cifrar por defecto todos los datos en tránsito en la capa de transporte (capa 4 del modelo OSI).Sin embargo, la información sensible o sujeta a regulaciones exige protección adicional en reposo y en la capa de aplicación (capa 7).

A05 Injection

Es un fallo de la aplicación que permite enviar datos de usuario no confiables a un intérprete (por ejemplo, un navegador, una base de datos o la línea de comandos) y provoca que dicho intérprete ejecute partes de esos datos como comandos.

A06 Insecure Design

El diseño inseguro es una categoría amplia que abarca diversas debilidades. Los fallos de diseño y defectos de implementación tienen causas raíz distintas, se producen en etapas diferentes del proceso de desarrollo y requieren medidas de remediación diferentes.

A07 Authentication Failures

Cuando un atacante logra engañar a un sistema para que reconozca a un usuario inválido o incorrecto como legítimo, esta vulnerabilidad está presente.

A08 Software or Data Integrity Failures

Se refieren a código e infraestructura que no protegen contra el tratamiento de código o datos inválidos o no confiables como confiables y válidos.

A09 Security Logging & Alerting Failures

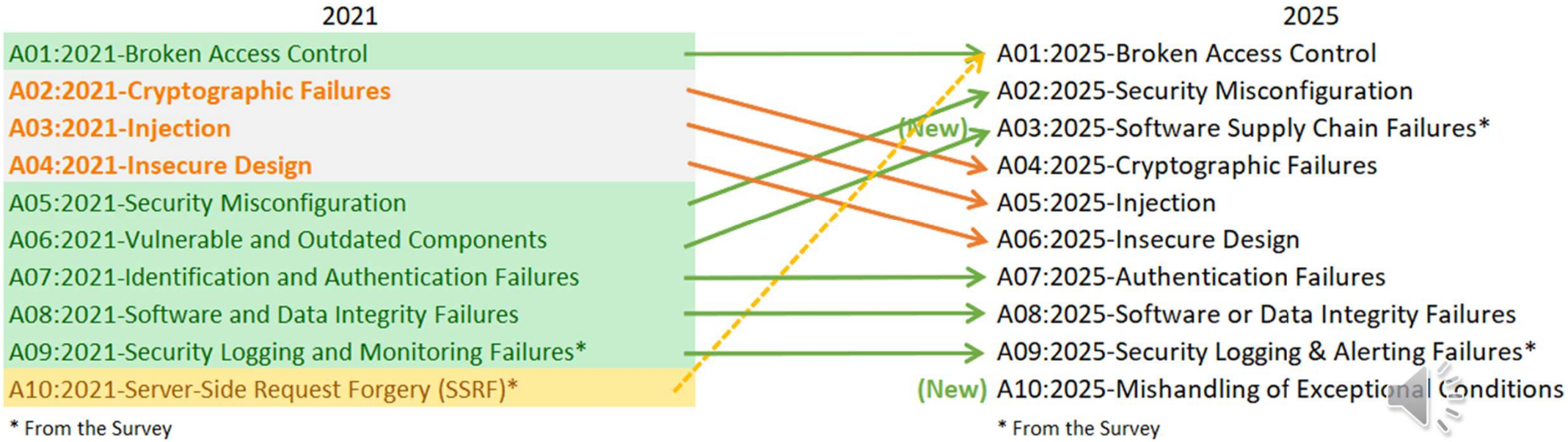
Sin registro y monitorización, no se pueden detectar ataques ni brechas, y sin alertas es muy difícil responder rápida y eficazmente durante un incidente de seguridad.

A10 Mishandling of Exceptional Conditions

Ocurre cuando los programas no logran prevenir, detectar ni responder a situaciones inusuales e impredecibles, lo que conduce a fallos, comportamientos inesperados y, a veces, vulnerabilidades.

3.2 OWASP TOP 10

OWASP TOP 10



CWE: Common Weakness Enumeration (https://cwe.mitre.org/)
CVE: Common Vulnerabilities and Exposures (https://www.cve.org/)